

D385

Software Security and Testing

Armored Drill

8 concepts · 12 items · 4 transfer items

What this is. Every concept in this course's public description, re-asked with more disguise than a practice test uses. Each stem carries facts that do not decide it. Every wrong answer is a named trap.

Source. Scope from the course's public description in the WGU Institutional Catalog (September 2026); items written from the field's standard body of knowledge. No WGU assessment item, course material or proprietary content is used or reproduced. Not affiliated with or endorsed by Western Governors University.

Method © 2026 Erik Daniel Lindquist — Course Mastery Coach, armored drill. Items drafted with AI assistance under his direction.

How to run it

Paper first. Pencil. One pass, no notes, a timer if you want the pressure.

1. **Before you read the options**, fill the strip under the item: the target word (what is actually being asked), and the one fact in the stem that decides it.
2. **Principle before arithmetic**. Name the rule, then compute.
3. **Camouflage**. Most of every stem does not matter. Ask: which single fact decides this?
4. **Inverse pairs are the bait**. If two options are opposites, one of them is the trap built for you.
5. **Mark sure, unsure or guess** honestly. Sure-and-wrong is the most valuable miss on the page — it is a wrong mental model.
6. **Absolutes** (always, never, guarantee) are usually wrong. And recognizing an answer is not the same as owning it.
7. Items with a **heavy black bar** on the left are **transfer items**: the same principle, reversed or solved for a different variable.
8. Stop at the STOP page. Then grade, fill the triage grid, and tally the traps you fell for. The biggest tally is what you drill next.

The strip, filled in, looks like this:

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	_____	

Items

1.

A developer at a fast-growing online bookstore builds a search query by joining the user's search text into a SQL string. The bookstore's catalog has 2 million titles. The team lead asks for the best fix. What is it?

- A. Limit the search box to 50 characters.
- B. Check the input with JavaScript in the browser.
- C. Move the catalog to a larger database server.
- D. Use a parameterized query that binds the search text as data.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

2.

A community forum, run by volunteers since 2012, shows each user's profile bio on their public page. The forum already uses HTTPS. What control most directly prevents a bio from running script in other visitors' browsers?

- A. Allow bios only from long-time members.
- B. Encrypt the bio in the database.
- C. Encode the bio for HTML output when displaying it.
- D. HTTPS already prevents this.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

3.

A patient logs in to a clinic portal and views her lab results at /results/1042. She changes the URL to /results/1043 and sees another patient's results. The portal was launched with a large press event. What failed?

- A. Authentication — her login was not verified.
- B. Encryption — the results were not encrypted.
- C. Authorization — the server did not check that the record belongs to her.
- D. Nothing; logged-in users may view any record.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

4. [TRANSFER — reversed stem / different variable]

A user enters the correct password and a valid one-time code. Which question has this answered?

- A.** Who the user is (authentication).
- B.** What the user may do (authorization).
- C.** Whether the data is encrypted.
- D.** Everything; no further checks are needed.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

5.

A startup with 12 engineers is building sign-up for its app. The CTO, a former game developer, suggests encrypting passwords with AES so support staff can read them back if users forget. What should the team do instead?

- A.** Store passwords in plain text on a secure server.
- B.** Store a salted, slow one-way hash and offer a reset process.
- C.** Encrypt with AES as suggested.
- D.** Store a fast, unsalted hash.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

6. [TRANSFER — reversed stem / different variable]

An app must store customers' bank account numbers and show them to staff when processing refunds. Which protection fits?

- A.** Base64 encoding.
- B.** Encryption with well-managed keys.
- C.** A salted one-way hash.
- D.** Output encoding.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

7.

A research team of 10 people, spread across three universities, wants every pair to share a unique symmetric key. How many keys are needed?

- A.** 45
- B.** 20
- C.** 90
- D.** 3

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

8. [TRANSFER — reversed stem / different variable]

A 50-person company switches to public/private key pairs. How many keys in total are needed?

- A.** 2,450
- B.** 1,225
- C.** 50
- D.** 100

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

9.

A reporting app only reads sales data, but its database account has full administrator rights. The app was written by a contractor who has since retired. What should be changed?

- A.** Give it read access to every database in the company.
- B.** Keep admin rights so nothing breaks.
- C.** Find the retired contractor to ask.
- D.** Give the app's account read-only access to the sales tables it needs.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

10.

While debugging, a developer at a payroll company, which has offices in two countries, finds that the login service writes each full request, including the password field, to the application log. What is the right fix?

- A.** Turn off all logging for the login service.
- B.** Keep logging but restrict log access to one country.
- C.** Stop logging secrets; log the event, user, time, source, and outcome instead.
- D.** Encrypt the log files and keep logging passwords.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

11.

A food-delivery company's mobile app limits users to 5 order-status checks per minute. The API server has no limit of its own. The app has a 4.8-star rating. What is the weakness?

- A.** The rating shows the API is secure.
- B.** Anyone can call the API directly and skip the app's limit; rate limiting must be on the server.
- C.** There is no weakness because the app enforces it.
- D.** The limit of 5 is too high.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

12. [TRANSFER — reversed stem / different variable]

An API checks that each request has a valid token but returns any order ID the caller asks for. Which control is missing?

- A.** Object-level authorization.
- B.** Output encoding.
- C.** Authentication.
- D.** Rate limiting.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	—	

STOP

Answers and dissection follow. Finish every item and every strip first.

Key and dissection

Struck-through text is the camouflage: facts that do not decide the item.

1. Answer D Concept 1

A developer ~~at a fast-growing online bookstore~~ builds a search query by joining the user's search text into a SQL string. ~~The bookstore's catalog has 2 million titles.~~ The team lead asks for the best fix. What is it?

Target word: injection fix **Decides:** Input is built into the query string.

A	Dropped element	Length limits reduce but do not remove the risk.
B	Adjacent category	Client checks can be bypassed; the server must protect itself.
C	Camouflage	Catalog size has nothing to do with injection.
D	Correct	Input can never change the query's structure.

2. Answer C Concept 2

A community forum, ~~run by volunteers since 2012,~~ shows each user's profile bio on their public page. The forum already uses HTTPS. What control most directly prevents a bio from running script in other visitors' browsers?

Target word: XSS control **Decides:** Untrusted text is displayed on a page.

A	Camouflage	Trust level is not a technical control.
B	Adjacent category	Storage encryption does not change how it renders.
C	Correct	Encoding makes the browser show it as text.
D	Confusion set	HTTPS protects data in transit, not page content.

3. Answer C Concept 3

A patient logs in to a clinic portal and views her lab results at /results/1042. She changes the URL to /results/1043 and sees another patient's results. ~~The portal was launched with a large press event.~~ What failed?

Target word: which control failed **Decides:** She was logged in, but the server did not check ownership.

A	Inverted operation	She was properly logged in.
B	Adjacent category	Encryption would not stop an authorized-looking request.
C	Correct	Authentication worked; access control per object did not.
D	Absolute language	Being logged in does not grant access to all data.

4. Answer A Concept 3 • transfer

A user enters the correct password and a valid one-time code. Which question has this answered?

Target word: what was established **Decides:** Credentials prove identity.

A	Correct	Factors verify identity.
B	Inverted operation	Permissions are a separate check.
C	Confusion set	Unrelated to sign-in.
D	Absolute language	Each request still needs authorization.

5. Answer B Concept 4

A startup with 12 engineers is building sign-up for its app. The CTO, a former game developer, suggests encrypting passwords with AES so support staff can read them back if users forget. What should the team do instead?

Target word: password storage **Decides:** Passwords should never be recoverable.

A	Absolute language	No server is secure enough to justify plain text.
B	Correct	Hashes cannot be reversed; resets replace recovery.
C	Inverted operation	Reversible storage means a key leak exposes every password.
D	Dropped element	Drops the salt and slowness that resist cracking.

6. Answer B Concept 4 · transfer

An app must store customers' bank account numbers and show them to staff when processing refunds. Which protection fits?

Target word: protection for data that must be read back **Decides:** The data must be recovered.

A	Confusion set	Encoding is not protection; anyone can decode it.
B	Correct	Reversible protection for data you need later.
C	Inverted operation	Hashes cannot be read back.
D	Adjacent category	Prevents script injection, not data exposure.

7. Answer A Concept 5

A research team of 10 people, spread across three universities, wants every pair to share a unique symmetric key. How many keys are needed?

Target word: symmetric key count **Decides:** $n(n-1)/2$ with $n = 10$.

A	Correct	$10 \times 9 / 2 = 45$.
B	Confusion set	$2n$ is the asymmetric count.
C	Dropped element	Forgets to divide by 2; each pair shares one key.
D	Wrong stem number	The number of universities.

8. Answer D Concept 5 · transfer

A 50-person company switches to public/private key pairs. How many keys in total are needed?

Target word: asymmetric key count **Decides:** Each person has one key pair.

A	Inverted operation	Multiplies $n(n-1)$ without dividing and uses the wrong model.
B	Confusion set	That is the symmetric pairwise count.
C	Dropped element	Counts only one key per person.
D	Correct	$2 \times 50 = 100$.

9. Answer D Concept 6

A reporting app only reads sales data, but its database account has full administrator rights. The app was written by a contractor ~~who has since retired~~. What should be changed?

Target word: privilege fix **Decides:** The app only needs read access.

A	Dropped element	Read-only but far wider than needed.
B	Inverted operation	Convenience over safety.
C	Camouflage	The access need is already clear.
D	Correct	Least privilege limits damage if the app is compromised.

10. Answer C Concept 7

While debugging, a developer at a payroll company, ~~which has offices in two countries~~, finds that the login service writes each full request, including the password field, to the application log. What is the right fix?

Target word: logging fix **Decides:** Secrets are being written to logs.

A	Absolute language	Removes needed security records.
B	Camouflage	Office locations do not fix the exposure.
C	Correct	Keeps useful security data without exposing credentials.
D	Dropped element	Protects the file but still stores secrets that should never be kept.

11. Answer B Concept 8

A food-delivery company's mobile app limits users to 5 order-status checks per minute. The API server has no limit of its own. ~~The app has a 4.8 star rating~~. What is the weakness?

Target word: API weakness **Decides:** The limit exists only in the client.

A	Camouflage	User ratings do not measure security.
B	Correct	Client-side controls can be bypassed.
C	Inverted operation	Trusts the client.
D	Wrong stem number	The number is not the problem; where it is enforced is.

12. Answer A Concept 8 · transfer

An API checks that each request has a valid token but returns any order ID the caller asks for. Which control is missing?

Target word: missing API control **Decides:** Token proves identity; ownership is not checked.

A	Correct	Each order must be checked against the caller.
B	Confusion set	Prevents script injection, not data access.
C	Inverted operation	The token already authenticates.
D	Adjacent category	Limits volume, not access to others' data.

Triage grid

Write each item number in the box it belongs to.

	Right	Wrong
Sure	Owned.	Concept inversion — top priority. A wrong mental model; it survives rewording.
Unsure / guess	Recognition, not mastery. Re-drill with the transfer.	Not learned yet.

Trap tally

For every miss, find the letter you chose in the key and tally its trap. The biggest number is the pattern to drill.

Trap	What it does	In this drill	Your misses
Dropped element	Leaves out a required term or step.	6	
Wrong stem number	A figure copied from the prompt that is not the answer.	2	
Adjacent category	The right idea in the wrong bucket.	5	
Inverted operation	Direction flipped: add/subtract, cause/effect, higher/lower.	8	
Absolute language	Always, never, guarantee — where judgment applies.	4	
Confusion set	Every option is real; the test is exact role-matching.	6	
Camouflage	Answers a stem fact that was never the question.	5	

Anchor rows — the concept list

One row per concept: the rule to lock in, the trap that catches people, and the tell in the question that signals it.

#	Concept	Rule	Trap	Tell
1	Parameterized queries	Pass user input to the database as bound parameters, never by building query strings, so input is always treated as data.	Relying on escaping or client-side checks instead of parameters.	User input joined into a SQL string.
2	Output encoding against XSS	Encode untrusted data for the context where it is displayed (HTML, attribute, JavaScript) so the browser treats it as text.	Thinking HTTPS or input length limits stop cross-site scripting.	User-supplied text shown back on a web page.
3	Authentication vs. authorization	Authentication proves who you are; authorization decides what you may do, and must be checked on the server for every request.	Assuming a logged-in user may access any record.	A signed-in user reaching data that belongs to someone else.
4	Hashing vs. encryption for passwords	Store passwords with a salted, slow, one-way hash (e.g., bcrypt, Argon2); encryption is reversible and meant for data you need to read back.	Encrypting passwords, or using a fast unsalted hash.	How to store passwords vs. how to protect data you must read later.
5	Symmetric vs. asymmetric cryptography	Symmetric uses one shared key (fast, hard to distribute); asymmetric uses a public/private pair (easy key exchange, slower). n users need $n(n-1)/2$ symmetric keys or $2n$ asymmetric keys.	Encrypting with the sender's private key for confidentiality.	Key counts or which key encrypts for whom.
6	Least privilege for code and services	Each app, service account, and file permission gets only the access its function needs.	Running the app's database account as an administrator for convenience.	A service account with rights far beyond its task.
7	Secure logging and log analysis	Log security-relevant events with time, user, source, and outcome; never log secrets such as passwords or tokens; look for patterns across entries.	Logging full request bodies with credentials for debugging.	A log line containing a password or a burst of failed logins.
8	API security controls	APIs need server-side authentication, authorization per object, input validation, and rate limiting.	Trusting the mobile app to enforce limits.	Controls that exist only in the client.

Course scope (public description): This course prepares you to recognize security vulnerabilities in software, to plan interventions to address security vulnerabilities where they exist, and to develop and test these interventions. The course covers topics in Web security, permissions, and identity security; debugging; log file analysis; API security; and encryption and cryptography concepts.